

Wissen Sie, wie sicher Ihre Secrets wirklich sind?

HashiCorp Vault oder OpenBao läuft bei Ihnen seit Jahren, und alle verlassen sich darauf. Aber wann hat zuletzt jemand geprüft, ob Unseal-Konzept, Policies, Backups und Upgrades noch dem Stand entsprechen, den Ihre Prüfer und Ihr Sicherheitsteam erwarten? Der Health Check gibt Ihnen in einer Woche eine unabhängige Antwort, mit einem klaren Plan, was zuerst zu tun ist.

Thomas Zachmann · thomas@zachmann.work · thomaszachmann.de/vault-health-check

FÜR WEN

Typische Ausgangslagen

Läuft, aber niemand weiß mehr genau, wie

„Das ursprüngliche Projektteam ist längst weitergezogen.“

Vault ist produktiv, Anwendungen hängen daran, aber Konzept und Konfiguration hat seit dem Aufbau niemand mehr ganzheitlich angesehen.

Ein Audit steht an

„Wir müssen nachweisen, dass das sauber ist.“

ISO 27001, BSI-Grundschutz, BAIT/VAIT oder DORA verlangen nachvollziehbare Zugriffe, Protokollierung und geprobte Wiederherstellung. Der Health Check zeigt, wo Sie stehen, bevor es der Prüfer tut.

Upgrade oder Wechsel zu OpenBao

„Seit der Lizenzänderung fragen wir uns, wie es weitergeht.“

Bevor Sie upgraden oder migrieren, sollten Sie wissen, worauf Sie aufbauen. Die Bestandsaufnahme ist die Grundlage für jede dieser Entscheidungen.

Kubernetes holt sich Secrets, aber wer darf was?

„Jedes Team hat sich irgendwann eine Rolle angeeignet.“

Kubernetes Auth, Agent Injection und External Secrets Operator sind schnell eingerichtet. Ob die Berechtigungen dahinter noch stimmen, ist eine andere Frage.

UMFANG

Was ich prüfe

Architektur und HA

Cluster-Aufbau, Storage-Backend, Ausfallsicherheit, Performance-Reserven

Unseal und Root-Zugang	Auto-Unseal (z. B. HSM oder KMS), Umgang mit Root-Token und Recovery Keys
Authentifizierung und Policies	Auth-Methoden, Rollen, Least Privilege, verwaiste oder zu weit gefasste Berechtigungen
Kubernetes-Integration	Kubernetes Auth, Agent Injection, External Secrets Operator, Trennung nach Namespaces
Betrieb	Backup und <i>getesteteter</i> Restore, Monitoring, Audit-Logs, Upgrade-Fähigkeit
Automatisierung	Konfiguration als Code oder von Hand geklickt? Nachvollziehbarkeit von Änderungen
Lizenz und Perspektive	HashiCorp Vault nach der Lizenzänderung oder OpenBao: was die Entscheidung für Sie bedeutet

Ich brauche nur lesenden Zugriff. An Ihrer produktiven Umgebung wird während des Health Checks nichts verändert.

ERGEBNIS

Was Sie bekommen

Bericht	Ampelbewertung pro Bereich, verständlich auch für Management und Audit
Maßnahmenplan	Priorisiert: was sofort kritisch ist, was in die nächsten drei Monate gehört, was Kür ist
Abschlusspräsentation	60 Minuten mit Ihrem Plattform- und Security-Team, Raum für alle Fragen
Optional	Konfigurationsvorschläge als Code (Terraform/OpenTofu) für die wichtigsten Maßnahmen

Ablauf

1. Kick-off	Ziele, Zugänge, Ansprechpartner	1 Std. remote
2. Analyse	Konfiguration, Policies, Betrieb, Gespräche mit dem Team	2-3 Tage
3. Bericht	Bewertung und Maßnahmenplan	1 Tag
4. Abschluss	Präsentation und Fragen	1 Std.

Ich arbeite remote, auf Wunsch auch vor Ort.

ANGEBOT

Varianten und Angebot

Nach einem kurzen Erstgespräch erhalten Sie ein schriftliches Angebot mit Festpreis für den vereinbarten Umfang.

Basis

- ein Vault/OpenBao-Cluster
- bis ca. 50 angebundene Anwendungen
- Bericht, Maßnahmenplan und Abschlusspräsentation

Erweitert

- mehrere Cluster oder Umgebungen
- inklusive Restore-Test
- Kubernetes-Integration im Detail

Der Health Check ist eine technische Bestandsaufnahme und ersetzt kein formales Prüfungs- oder Zertifizierungsteststat.

BELEGE

Warum ich

Praxis	Ich baue und betreibe Vault/OpenBao selbst , zuletzt als zentralen Secret Store einer On-Premises-Kubernetes-Plattform: Berechtigungskonzept, Auto-Unseal über ein Hardware-HSM, Kubernetes Auth, Injection und External Secrets Operator, vollständig als Infrastructure as Code.
Buch	„Vault in Practice“ : ein praxisnaher Lab-Guide zu HashiCorp Vault und OpenBao (Leanpub, 581 Seiten).
Umfelder	Seit 2020 in regulierten Umfeldern, unter anderem öffentlicher Sektor und Banken.
Zertifikate	CKS, CKA, CKAD

NÄCHSTER SCHRITT

30 Minuten, unverbindlich

Wir klären, ob ein Health Check für Ihre Situation sinnvoll ist und welches Paket passt. Schreiben Sie mir kurz, welche Version Sie einsetzen und wie viele Cluster es sind.

Thomas Zachmann · Freiberuflicher Platform Engineer · Hamburg
thomas@zachmann.work · thomaszachmann.de